

Threat Modeling Frameworks

CompTIA SecAI+: AI Security Certification Complete Exam Prep 2026 | Section 10: AI Threat Modeling Resources

1. Why No Single Framework Is Enough

A recurring mistake in AI security programs is selecting one threat modeling framework and applying it as a universal solution. In reality, every major framework was designed with a specific lens — some organize threats by category, others rank them by business impact, and still others are built to scale across enterprise development cycles. AI systems compound this challenge because they introduce threat surfaces that traditional frameworks were not built to address in full: training data pipelines, inference APIs, model versioning, embedding stores, and foundation-model supply chains. Using multiple frameworks in combination — cross-checking each against the AI system's architecture — produces a more complete threat model than any single methodology can provide. This guide covers the two most widely deployed frameworks (STRIDE and PASTA), three additional methodologies (OCTAVE, VAST, Trike), and a practical approach to selecting and combining them for AI security engagements.

2. STRIDE at a Glance: Six Threat Categories

STRIDE, originally developed by Microsoft, organizes security threats into six named categories rather than prescribing a specific process. Its strength is systematic completeness: given any component in an AI architecture, a practitioner can march through all six categories and ask whether that threat type applies. The table below shows each category with its classical meaning and its AI-specific manifestation.

STRIDE Category	Classical Threat	AI-Specific Manifestation
Spoofing	Impersonating a user or system identity	Fake data sources, forged training data, spoofed API callers
Tampering	Unauthorized modification of data or code	Poisoned training sets, altered model weights, manipulated inference inputs
Repudiation	Denying having performed an action	No audit trail for who uploaded data, who triggered retraining, who approved deployment
Information Disclosure	Exposing sensitive data to unauthorized parties	Model inversion attacks, training-data extraction, leaking security policies via LLM responses
Denial of Service	Making a system unavailable or degraded	Inference API flooding, oversized prompt attacks, GPU exhaustion during incidents
Elevation of Privilege	Gaining more permissions than authorized	Bypassing RBAC on model management consoles, hijacking MLOps pipeline credentials

3. Spoofing and Tampering: The Data-Integrity Pair

Spoofing and Tampering are logically linked because attackers who successfully spoof a trusted identity often do so specifically to enable subsequent tampering. In AI systems, the attack surface for both is larger than in traditional software because models ingest data from diverse, often external, sources continuously.

- Spoofing mitigations: authenticate every data source before ingestion using digital signatures on threat-feed payloads, mTLS for inference APIs, and verified provenance metadata attached to every training dataset record.
- Tampering mitigations: enforce cryptographic integrity using SHA-256 hashes on training artefacts, signed model binaries stored in immutable object storage, and strict pull-request controls on any code that touches the training pipeline.
- Combined defense: treat the AI data supply chain like a software supply chain. Every dataset should have a Bill of Materials (DBOM) recording origin, transformations, and the identity of every party that touched it.
- Detection layer: anomaly detection on model performance metrics catches silent tampering that bypasses static integrity checks. A sudden drop in recall for a malware classifier after a dataset update is a red flag worth investigating.

4. Repudiation and Information Disclosure in AI Contexts

Repudiation is often underweighted in AI security reviews because traditional attack scenarios do not typically involve denying actions. But AI systems make high-stakes automated decisions — flagging transactions, grading job applications, escalating security alerts — and the ability to reconstruct who authorized what is critical both for incident response and regulatory compliance. Without tamper-evident audit logs, investigations stall at 'We think the model was modified, but we cannot prove when or by whom.'

Information Disclosure in AI is more subtle than a misconfigured storage bucket. Model inversion attacks allow adversaries to reconstruct representative samples from a training set by submitting carefully crafted inputs and observing output distributions. Membership inference attacks reveal whether a specific record was in the training data — a serious privacy violation if the training set contained medical records or personally identifiable information. For security AI specifically, information disclosure can expose the logic of a detection model, allowing attackers to craft inputs that reliably evade it. Countermeasures include differential privacy during training, output confidence score suppression, and strict API rate limiting to slow inference-time probing.

5. Denial of Service and Elevation of Privilege: Availability and Authority

Denial of Service against AI systems is asymmetric: the cost of an attack is low while the cost of defense is high, particularly for GPU-intensive inference workloads. Sponge attacks exploit this asymmetry by submitting inputs engineered to maximise compute time — for example, adversarial text designed to trigger worst-case tokenization or attention computation in a large language model. Operational controls such as autoscaling, input-length caps, token budgets, and circuit breakers reduce exposure, but architects must also design for graceful degradation: when the AI component is overloaded, the security process should fall back to a defined manual procedure rather than silently stopping alert production.

Elevation of Privilege in MLOps: MLOps pipelines often grant broad permissions to service accounts that trigger retraining. If an attacker compromises that service account through a leaked CI/CD secret, a vulnerable dependency, or a misconfigured IAM role, they can silently replace production models. Applying the principle of least privilege to training pipeline service accounts is a first-line control that security architects frequently overlook.

6. Applying STRIDE to an AI Architecture: A Structured Walkthrough

STRIDE becomes actionable when combined with a data-flow diagram (DFD) of the AI system. The process has four steps:

- Draw the DFD: identify all components including data sources, preprocessing pipelines, training infrastructure, model registry, inference service, downstream consumers, and monitoring stack. Label trust boundaries between each component.
- Enumerate elements: for each process, data store, external entity, and data flow, list which STRIDE categories apply. A training data store may be subject to Spoofing, Tampering, and Information Disclosure simultaneously.
- Generate threat statements: convert each applicable category into a specific, falsifiable statement such as 'An attacker who gains write access to the model registry can replace the production classifier with a backdoored version (Tampering).'
- Prioritise and assign: rate each threat by likelihood and impact, assign an owner, and document the planned control or accepted residual risk.

Real-World Incident — Hugging Face Spaces Token Leak (2024): Hugging Face disclosed that unauthorised parties accessed Spaces secrets — API tokens stored in the platform's shared hosting environment. The incident illustrated Elevation of Privilege (stolen tokens granted model-management access beyond the attacker's authorisation) and potential Information Disclosure (models and datasets stored under the compromised tokens). A STRIDE review of the secrets-management architecture would have flagged Elevation of Privilege as a high-risk category requiring hardware-backed secret storage and short-lived credential rotation.

7. PASTA: Process for Attack Simulation and Threat Analysis

Where STRIDE asks 'What categories of threats exist?', PASTA asks 'Which attacks pose the greatest business risk, and how would they actually unfold?' PASTA is a seven-stage, risk-centric methodology that bridges the gap between technical security analysis and business decision-making. It is particularly valuable when security teams must justify budget allocation to non-technical stakeholders or when regulatory frameworks require documented risk assessments rather than simple vulnerability lists.

PASTA's risk-centricity means that not every identified threat becomes a remediation project. Threats are evaluated by their likelihood given the realistic attacker profile targeting the organisation, the technical feasibility of exploitation, and the business impact if successful. The output is a prioritised risk register — not a flat list of vulnerabilities. For AI systems, this is especially important: the number of

potential threats in a large ML pipeline can be overwhelming, and PASTA provides the structure to focus effort where it matters most.

8. PASTA Seven Stages: Summary Reference

Stage	Name	Key Activity for AI Systems
1	Define Business Objectives	Identify what the AI system protects — threat intelligence, compliance data, detection logic — and why it matters to the organisation
2	Define Technical Scope	Map AI components, external dependencies, model APIs, data pipelines, and trust boundaries
3	Application Decomposition	Break the training pipeline, feature stores, model registry, and inference layer into analysable units; identify attack surfaces
4	Threat Analysis	Profile likely attackers (nation-state, cybercriminal, insider); map adversarial tactics and techniques to the AI attack surface
5	Vulnerability Analysis	Assess insecure configurations, unpatched MLOps dependencies, weak API authentication, and AI-specific weaknesses such as data poisoning risks
6	Attack Modeling	Build attack trees showing how a threat actor navigates from initial access to high-value targets through identified vulnerabilities
7	Risk and Impact Analysis	Score each attack scenario by likelihood multiplied by business impact; produce a prioritised risk register to drive investment decisions

9. OCTAVE, VAST, and Trike: Complementary Perspectives

Three additional frameworks extend the threat modeling toolkit for contexts where STRIDE and PASTA have gaps.

Framework	Primary Lens	Best Fit For
OCTAVE (Operationally Critical Threat, Asset, and Vulnerability Evaluation)	Organisational risk management; asset-centric	Enterprise-wide AI risk assessments; aligning AI security with overall organisational risk appetite
VAST (Visual, Agile, and Simple Threat Modeling)	Scalable, process-integrated modeling	Large development organisations running continuous delivery; integrates threat modeling into agile sprints
Trike	Acceptable-risk definition; requirement-driven	Regulated industries where security requirements must be formally derived from defined risk thresholds

OCTAVE is workshop-based and involves business stakeholders directly in identifying critical assets and acceptable risk levels — a useful property when AI systems touch regulated data. VAST produces two model types: application threat models for developers and operational threat models for security operations, mapping well onto the distinction between an AI system's development security and its runtime security. Trike begins by asking what the acceptable level of risk is for each asset, then derives

required security controls from that baseline — a useful inversion for organisations that have already published risk appetite statements.

10. Combining Frameworks: A Layered Approach for AI Security

Experienced practitioners do not choose one framework and ignore the rest. A common layered approach for AI systems works as follows. Use STRIDE for systematic threat identification across the AI architecture, ensuring every component is examined through all six threat categories. Use PASTA to connect the resulting threat list to business risk, prioritise investment, and build the attack scenarios needed to justify controls to leadership. Supplement with MITRE ATLAS to map attacker TTPs specific to machine learning systems, and cross-reference OWASP ML Top 10 and LLM Top 10 for technology-specific vulnerability patterns. For enterprise-scale programs, layer OCTAVE or VAST to integrate the threat model with the organisation's broader GRC program.

Selection Heuristic: If the primary question is 'What can go wrong?' use STRIDE. If the question is 'What should we fix first given limited budget?' use PASTA. If the question is 'How do we scale threat modeling across 200 development teams?' use VAST. Combining all three with MITRE ATLAS covers the full spectrum for mature AI security programs.

Key Terms Glossary

Term	Definition
STRIDE	Microsoft-originated threat modeling framework organizing threats into Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege
PASTA	Process for Attack Simulation and Threat Analysis — a seven-stage, risk-centric threat modeling methodology connecting technical threats to business impact
OCTAVE	Operationally Critical Threat, Asset, and Vulnerability Evaluation — an asset-centric, workshop-based enterprise threat modeling approach
VAST	Visual, Agile, and Simple Threat Modeling — a scalable methodology designed to integrate into agile development pipelines across large organisations
Trike	A risk-management threat modeling approach that defines acceptable risk thresholds and derives required security controls from those thresholds
Data Flow Diagram (DFD)	A visual representation of an AI system's components, data flows, and trust boundaries — the starting artefact for a STRIDE analysis
Model Inversion Attack	An inference-time privacy attack in which an adversary reconstructs representative training samples by probing a deployed model's outputs
Membership Inference Attack	An attack that determines whether a specific record was included in a model's training dataset, violating the privacy of that record's subject

Sponge Attack	A denial-of-service technique submitting inputs engineered to maximise compute consumption by the target AI model
Attack Tree	A hierarchical diagram used in PASTA Stage 6 to visualize the sequence of steps an attacker must complete to reach a specific objective
MITRE ATLAS	Adversarial Threat Landscape for Artificial-Intelligence Systems — a knowledge base of AI-specific adversarial TTPs analogous to MITRE ATT&CK for traditional IT
Repudiation	The ability of a user or process to deny having performed an action; addressed in STRIDE through tamper-evident audit logging and digital signatures
Elevation of Privilege	A STRIDE category in which an attacker gains permissions beyond those authorised; a critical risk in MLOps pipeline service accounts

Quick Revision Checklist

- STRIDE covers six categories: Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege — memorize the acronym and one AI example per category.
- Start STRIDE analysis by drawing a data flow diagram; apply all six categories to every component and data flow across trust boundaries.
- PASTA is a seven-stage, risk-centric methodology connecting technical threats to business impact; it produces a prioritised risk register.
- PASTA Stage 6 builds attack trees showing attacker pathways; Stage 7 scores likelihood multiplied by impact to drive prioritisation.
- OCTAVE is asset-centric and workshop-based — best for enterprise-wide AI risk alignment with organisational risk appetite.
- VAST is designed for scale and agile integration — produces both application and operational threat models.
- Trike starts from a defined acceptable-risk threshold and derives security requirements from it.
- Model inversion and membership inference are Information Disclosure threats specific to AI — mitigated by differential privacy and output score suppression.
- Sponge attacks exploit the compute asymmetry of AI inference — mitigated by input-length caps, token budgets, and circuit breakers.
- Combine STRIDE with PASTA and MITRE ATLAS for comprehensive AI threat modeling; add OCTAVE or VAST for enterprise-scale programs.
- MLOps service account credentials are a high-risk Elevation of Privilege target — apply least-privilege IAM and short-lived credentials.
- MITRE ATLAS, OWASP ML Top 10, and LLM Top 10 complement framework-based threat models with AI-specific vulnerability patterns.

10 Exam-Based MCQs — Threat Modeling Frameworks

These questions are written in real CompTIA SecAI+ exam style — scenario-heavy with plausible distractors. Read every explanation, including for questions you answered correctly.

Q1. Scenario: Priya is a security architect at a financial services firm that uses an AI-powered fraud detection model. During a routine audit, the team discovers that the model registry does not enforce integrity checks on uploaded model binaries and that any engineer with repository access can overwrite the production model. A recent diff shows that the production model file was silently replaced two weeks ago, but no alert was triggered. Which action should the security architect prioritize to address this threat?

- A) Implement rate limiting on the inference API to prevent resource exhaustion
- B) Apply cryptographic hashes to training datasets and enforce digital signatures on deployed model binaries
- C) Enable differential privacy during model training to prevent output-based reconstruction
- D) Restrict inference API responses to top-1 predictions only, suppressing confidence scores

Answer: B **Explanation:** B is correct because the scenario describes Tampering — unauthorized modification of training data or model artefacts — which is directly addressed by integrity controls such as cryptographic hashes and digital signatures. A addresses Denial of Service, not Tampering. C addresses Information Disclosure (model inversion prevention), not data integrity. D also addresses Information Disclosure by limiting output detail, not modification of artefacts.

Q2. Scenario: Marcus leads a security team at a healthcare AI company. The team has been working through a PASTA-based threat model for a new diagnostic AI system. They have already defined the business objectives (Stage 1), mapped the technical scope (Stage 2), and decomposed the application components into an attack surface map (Stage 3). The team now needs to continue to the next PASTA stage. Which PASTA stage should the team complete NEXT to continue the methodology in the correct order?

- A) Define Business Objectives
- B) Application Decomposition
- C) Threat Analysis
- D) Attack Modeling

Answer: C **Explanation:** C is correct. PASTA Stage 4 is Threat Analysis, which follows Stage 3 (Application Decomposition) and precedes Stage 5 (Vulnerability Analysis). The team has completed Stages 1 through 3 and must now analyze the threat landscape by profiling attacker motivations and mapping tactics to the decomposed AI architecture. A is Stage 1, already completed. B is Stage 3, already completed. D is Stage 6, which comes after vulnerability analysis in Stage 5.

Q3. Scenario: Aiko is assessing the security of an AI system that ingests external threat intelligence feeds to retrain its malware classifier weekly. The assessment reveals that the ingestion pipeline validates the format of incoming data but does not verify the identity of the source submitting it. An attacker who can route traffic to the ingestion endpoint could submit falsified threat intelligence that appears to originate

from a trusted security vendor. Which STRIDE category BEST describes this threat, and what is the most appropriate primary control?

- A) Spoofing — implement mutual TLS authentication between the threat feed and the AI ingestion pipeline
- B) Tampering — deploy cryptographic hashes on all incoming threat intelligence records before ingestion
- C) Information Disclosure — encrypt threat feed data at rest and in transit using AES-256
- D) Repudiation — enable comprehensive audit logging to track which feed submissions entered the training pipeline

Answer: A **Explanation:** A is correct. The attacker is impersonating a trusted threat intelligence provider — a textbook Spoofing threat. The primary control is authentication: mutual TLS verifies both client and server identity, preventing a rogue source from presenting itself as a trusted feed. B addresses Tampering (data modification after ingestion), not identity impersonation at the point of entry. C addresses Information Disclosure, a different threat category. D addresses Repudiation, which concerns accountability after an action rather than identity verification before it.

Q4. Which framework was originally developed by Microsoft and organizes threats into six named categories?

- A) PASTA
- B) OCTAVE
- C) STRIDE
- D) VAST

Answer: C **Explanation:** C is correct. STRIDE was developed by Microsoft and uses the six-category acronym: Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege. A (PASTA) is a seven-stage risk-centric methodology, not a category-based framework from Microsoft. B (OCTAVE) is an asset-centric, workshop-based enterprise methodology developed by Carnegie Mellon's CERT. D (VAST) is a scalable framework designed for agile integration.

Q5. An AI model's inference API returns detailed confidence scores for each output class. Which AI-specific threat does this capability MOST directly enable?

- A) Sponge attacks targeting GPU resource exhaustion
- B) Model inversion attacks exploiting output distributions to reconstruct training data
- C) Elevation of Privilege attacks on the model registry
- D) Tampering with training dataset records through the inference endpoint

Answer: B **Explanation:** B is correct. Detailed confidence scores enable model inversion attacks — adversaries submit crafted inputs, observe the output distribution across classes, and reconstruct representative training samples. The richer the output detail, the more information is available. A (sponge attacks) exploit compute cost asymmetry, not output detail. C (Elevation of Privilege) targets authorisation controls in management systems, not inference outputs. D (Tampering via inference endpoint) is generally not possible since inference endpoints are designed as read-only query interfaces.

Q6. Which PASTA stage produces the prioritized risk register that guides security investment decisions?

- A) Stage 4 — Threat Analysis
- B) Stage 5 — Vulnerability Analysis
- C) Stage 6 — Attack Modeling
- D) Stage 7 — Risk and Impact Analysis

Answer: D **Explanation:** D is correct. Stage 7 (Risk and Impact Analysis) scores each attack scenario by likelihood and business impact to produce the prioritised risk register that drives investment decisions — this is PASTA's primary business-facing output. Stage 4 identifies threats (A) and Stage 5 identifies vulnerabilities (B); both are inputs to the attack modeling stage. Stage 6 builds attack trees and scenarios (C), which are in turn inputs to Stage 7 scoring. The risk register is the final, decision-ready deliverable.

Q7. Which of the following BEST describes the OCTAVE threat modeling framework?

- A) A six-category checklist for systematic threat identification across any system component
- B) An asset-centric, workshop-based methodology focused on organisational risk management
- C) A scalable framework designed to integrate threat modeling into agile development sprints
- D) A risk-management approach that begins by defining acceptable risk thresholds

Answer: B **Explanation:** B is correct. OCTAVE is characterised by its asset-centric focus and workshop-based process that involves business stakeholders alongside security professionals in identifying critical assets and acceptable risk. A describes STRIDE's category-based approach. C describes VAST, which was specifically designed for scale and agile process integration. D describes Trike, which begins from a defined acceptable-risk threshold and derives controls from it.

Q8. A security engineer wants to ensure that no AI system action — model retraining, dataset uploads, or deployment approvals — can be denied after the fact by the parties who performed them. Which STRIDE category does this requirement address?

- A) Spoofing
- B) Tampering
- C) Repudiation
- D) Information Disclosure

Answer: C **Explanation:** C is correct. Repudiation is the STRIDE category addressing the ability of parties to deny having performed actions. Tamper-evident audit logs, timestamped records, digital signatures, and strong authentication collectively address this threat. A (Spoofing) concerns identity impersonation before an action occurs. B (Tampering) concerns unauthorized modification of data or artefacts. D (Information Disclosure) concerns exposure of sensitive data to unauthorized parties — a different threat category entirely.

Q9. Which of the following BEST describes a sponge attack against an AI inference service?

- A) Submitting falsified training data that appears to originate from a trusted source
- B) Replacing a deployed model binary with a backdoored version via a compromised CI/CD pipeline
- C) Sending inputs engineered to maximise the compute resources consumed per inference request
- D) Probing a model's output confidence scores to reconstruct representative training samples

Answer: C **Explanation:** C is correct. A sponge attack is a denial-of-service technique that submits inputs specifically crafted to consume maximum compute resources — CPU, GPU, or memory — per request, exploiting the asymmetry between the low cost of sending requests and the high cost of processing them. A describes Spoofing of a training data source. B describes Elevation of Privilege via a compromised MLOps pipeline (Tampering of the production model). D describes a model inversion attack targeting Information Disclosure.

Q10. Which combination of resources provides the MOST comprehensive threat model for an enterprise AI security program?

- A) STRIDE alone, applied systematically to every AI component
- B) PASTA alone, run as a one-time engagement before the AI system launches
- C) STRIDE for threat identification, PASTA for risk prioritisation, and MITRE ATLAS for AI-specific TTP mapping
- D) VAST alone, integrated into the agile development process

Answer: C **Explanation:** C is correct. A layered approach combining STRIDE (systematic threat identification), PASTA (risk-centric prioritisation with attack scenarios), and MITRE ATLAS (AI-specific adversarial TTP mapping) covers both breadth and depth for enterprise AI security programs. A (STRIDE alone) identifies threats but does not prioritise by business risk or cover AI-specific TTPs. B (PASTA alone, one-time) misses AI-specific TTPs and does not provide ongoing coverage. D (VAST alone) addresses scale and process integration but lacks the risk-scoring output of PASTA and the AI-specific TTP coverage of ATLAS.